

Termin 1 – Grundlagen der Resilienz: Safety & Security

Prof. Dr. Dirk Loomans

29. September 2026

Vorlesungsskript • Grundlagen der Resilienz • Cyber Security Management (B.Sc.), 1. Semester • Hochschule Mainz

Vorbemerkung: Dieses Skript dient als Vorlesungsbegleitung und erhebt keinen akademischen Anspruch. Dennoch kann es bei der Klausurvorbereitung hilfreich sein. Kommentare und Verbesserungsvorschläge gerne an den Autor über dirk.loomans@hs-mainz.de.

Leitfrage

IT-Systeme sind nie vollkommen sicher. Wie schnell können wir uns nach einer Störung erholen und weiterarbeiten?

Einstieg: Wie lange darf euer Lieblingsspiel down sein?

Lernziele

Nach diesem Termin können Studierende

- den Begriff der Resilienz definieren und von Robustheit, Zuverlässigkeit und Sicherheit abgrenzen,
- den Unterschied zwischen Safety (Betriebssicherheit) und Security (Angriffssicherheit) erläutern,
- technische und organisatorische Resilienzprinzipien benennen und anwenden,
- Resilienz in Cyber-Security-Management, Business Continuity und Incident Response einordnen.

Fachinhalte

Begriff und Bedeutung

Resilienz bezeichnet die Fähigkeit eines Systems, trotz interner oder externer Störungen funktionsfähig zu bleiben, die Funktionsfähigkeit rasch wiederherzustellen und sich im Zeitverlauf anzupassen. In der Cyber-Sicherheit ergänzt Resilienz die klassische Prävention um frühzeitiges Erkennen (Detection), wirksame Reaktion (Response) und schnelle Wiederherstellung (Recovery).

Das Ziel ist nicht Unverwundbarkeit, sondern Reaktions- und Wiederherstellungsfähigkeit: robust designen, Störungen erkennen, reagieren, wiederherstellen.

Herkunft des Begriffs

Der Resilienzbegriff hat Wurzeln in Materialwissenschaft, Physik, Psychologie und Systemtheorie. Heute wird er auf technische und organisatorische Systeme übertragen. Resilience Engineering betont vier Fähigkeiten soziotechnischer Systeme: *anticipate, monitor, respond, learn* [1].

Safety und Security

	Safety	Security
Schutz vor	unbeabsichtigten Fehlern und Unfällen	absichtlichen, intelligenten Angriffen
Beispiele	Hardwaredefekt, Stromausfall, Brand	Ransomware, Social Engineering, Hacking

Beide beeinflussen die Resilienz eines Systems. Resilienz integriert beide Perspektiven und adressiert gerade die Übergänge in vernetzten OT- und IoT-Kontexten: Ein Safety-Ereignis kann zum Security-Vektor werden und umgekehrt. Kurz: **Safety + Security + Adaptivität = Resilienz**.

Physikalisch-systemische Perspektive

Resilienz ist die Fähigkeit zur Rückkehr in einen akzeptablen Funktionszustand nach einer Auslenkung. Analogie: Pendel oder gedämpfter Schwingkreis – Störung, Auslenkung, Rückkehr zur Balance. Elastizität steht gegen Fragilität (Gummi gegen Glas). In IT-Systemen übernehmen Kontrollschleifen wie Monitoring, Alerting und Autoscaling die Rolle von Regelkreisen.

Technische Resilienzprinzipien

- **Redundanz** – mehrere Wege und Komponenten, etwa Multi-AZ oder Multi-Region.
- **Diversität** – heterogene Implementierungen und Lieferantenvielfalt reduzieren Kaskadenfehler.
- **Wiederherstellbarkeit** – geplante, getestete und automatisierte Wiederanlaufprozesse (Backups, DR-Prozesse).
- **Adaptivität** – dynamische Anpassung, Skalierung, Umschalten, Lernen; Chaos Engineering als Testmethode.

Diese vier Prinzipien sind der technische Kern der gesamten Lehrveranstaltung und werden in Termin 3 vertieft.

Warum Prävention nicht reicht

Zero-Days, Lieferketten und menschliche Fehler machen 100 % Prävention unmöglich. Resilienz ist die letzte Verteidigungslinie. Deshalb ist sie ein Management- und Architekturthema, eingebettet in Standards und Frameworks und verbunden mit Incident Response, BCM und IT-Service-Continuity-Management.

Praxisbeispiele

- **Ransomware in einer Verwaltung:** koordiniertes Incident- und Krisenmanagement, offline verifizierte Backups, priorisierter Wiederanlauf gemäß BCM-Plan. Recovery und Kommunikation sind entscheidend.
- **DDoS auf einen Online-Dienst:** Anycast, CDN und WAF, elastische Skalierung und Traffic-Filterung, transparente Status-Kommunikation, Übungen (Game Days).
- **Smart Home / OT:** Ein Safety-Ereignis wird zum Security-Vektor; Segmentierung, sichere Updates, Fail-Safe-Modi.

Diskussionsfrage: Welche Maßnahmen beschleunigen die Wiederherstellung?

Normativer Bezug

NIST SP 800-160 Vol. 2 operationalisiert Cyber-Resilienz als Engineering-Aufgabe [2]. ISO/IEC 27031 adressiert die IKT-Bereitschaft für Business Continuity [3], der BSI-Standard 200-4 das Business Continuity Management [4]. ENISA veröffentlicht sektorspezifische Resilienz-Leitfäden.

i Hinweis zur Begrifflichkeit

Die Archivunterlagen beschreiben das NIST-Modell mit „resist, recover, re-constitute, re-architect,, Revision 1 von NIST SP 800-160 Vol. 2 formuliert die Ziele *Anticipate, Withstand, Recover, Adapt*. Siehe [Hinweise zur Aktualität](#).

Übung: Safety oder Security?

Gruppenaufgabe mit Szenarien: Cloud-Gaming, Krankenhaus-IT, Smart Home, autonomes Fahrzeug, Banking-App.

1. Safety- und Security-Risiken identifizieren.
2. Risiken Safety oder Security zuordnen; Übergänge benennen.
3. Resilienzmaßnahmen vorschlagen und kritische Funktionen priorisieren.
4. 5-Minuten-Kurzpräsentation pro Gruppe.

Prüfungsrelevante Leitfragen

1. Definieren Sie Resilienz im Kontext von IT-Systemen und grenzen Sie den Begriff von Robustheit ab.
2. Erläutern Sie den Unterschied zwischen Safety und Security und nennen Sie je ein Beispiel aus IT/OT.
3. Nennen und erklären Sie drei technische Prinzipien, die Resilienz erhöhen (mit kurzen Beispielen).
4. Skizzieren Sie die Rolle von ISO/IEC 27031 und BSI-Standard 200-4 für Wiederanlauf und BCM.
5. Beschreiben Sie den Detect-Respond-Recover-Gedanken.

Kernpunkte

- „Sicherheit schützt – Resilienz überlebt., Prävention ist notwendig, aber nicht hinreichend.
- Safety und Security adressieren unterschiedliche Ursachen – Resilienz integriert beide Perspektiven.
- Design for Failure: Redundanz, Diversität, Wiederherstellbarkeit und Adaptivität sind Leitplanken.
- Resilienz erfordert Technik, Prozesse und Menschen – und lebt von Übung und Lernen.

Vor- und Nachbereitung

Hausaufgabe: Recherchieren Sie ein Beispiel für ein System, das sich nach einer Störung besonders schnell erholt hat.

Ausblick Termin 2: Modelle und Metriken der Resilienz (RTO, RPO, MTTR, MTBF).

Material aus dem Archiv

01 Grundlagen/01_Grundlagen der Resilienz.pptx (Foliensatz mit Sprechernotizen) und Skript_Sitzung1_Grundlagen_der_Resilienz.pdf.

Bibliografie

- [1] E. Hollnagel, D. D. Woods, und N. Leveson, Hrsg., *Resilience Engineering: Concepts and Precepts*. Aldershot: Ashgate, 2006.
- [2] R. Ross, V. Pillitteri, R. Graubart, D. Bodeau, und R. McQuaid, „Developing Cyber-Resilient Systems: A Systems Security Engineering Approach“, NIST Special Publication 800-160 Vol. 2 Rev. 1, Dez. 2021. doi: [10.6028/NIST.SP.800-160v2r1](https://doi.org/10.6028/NIST.SP.800-160v2r1).
- [3] „ISO/IEC 27031:2025 Cybersecurity – Information and communication technology readiness for business continuity“. [Online]. Verfügbar unter: <https://www.iso.org/standard/27031>
- [4] „BSI-Standard 200-4: Business Continuity Management“. Bonn, Mai 2023.